

— PGP TREINAMENTO • TEMPLATES INSTITUCIONAIS



PACOTE • 20 MODELOS EDITÁVEIS

Pacote *de Modelos*

Programa de Governança em Privacidade

20 templates prontos para edição — atos, políticas, fichas e formulários para a implementação da **LGPD** em instituições públicas.

EDIÇÃO

12 de junho de 2026

COMPANHEIRO DE

Cartilha do PGP



Como usar este Pacote

Este documento reúne **20 modelos editáveis** para implementação da LGPD em órgãos públicos. Diferente da Cartilha (guia descritivo), aqui você tem **templates prontos para editar** — abra, vá direto ao modelo que precisa e adapte.



Como os modelos estão organizados



Cabeçalho do modelo

Cada modelo começa com banner "Modelo NN — Nome" para fácil localização.



Caixa azul "Quando usar"

Logo abaixo do título: instrução breve de quando usar o modelo.



Corpo do template

Campos para preencher destacados em *[ITÁLICO COLCHETES]* — ex.

[NOME DA INSTITUIÇÃO].



Caixa amarela "Exemplo preenchido"

Ao final: exemplo preenchido com dados fictícios para você ver como fica.



Convenção de placeholders

Os campos a preencher seguem padrão de fácil identificação:

[NOME DA INSTITUIÇÃO] – nome completo
[CIDADE] – cidade-sede
[CNPJ] – CNPJ da Instituição
[NOME DO ENCARREGADO] – DPO designado(a)
[E-MAIL] e [TELEFONE] – contatos institucionais
[DATA] – data de emissão
[NOME DO PROCESSO], [NOME DO OPERADOR], [NOME DO TITULAR] –
contextuais

RECOMENDAÇÃO DE USO

Não preencher tudo de uma vez. O PGP é processo gradual — preencha os modelos na ordem das fases (Preliminar primeiro: Ato de Designação · Carta Alta Gestão · Termômetro), e vá avançando conforme o Plano de Ação.

Sugestão: salvar uma cópia ANTES de editar — o original fica intacto para futura consulta ou para distribuir a outros servidores.



Os 20 modelos

Organizados em **3 grupos** conforme o tipo de documento.

GRUPO 1 • 5 MODELOS



Documentos Formais

01	 Ato de Designação do Encarregado	Fase 1
02	 Carta para a Alta Gestão	Preliminar
03	 Roadmap de 90 dias	Preliminar
04	 Aviso de Privacidade público	Fase 6
05	 Documento do PRI — Plano de Resposta a Incidentes	Fase 7

GRUPO 2 • 6 MODELOS



Documentos Institucionais

06	 Política do PGP (documento mater)	Fase 5
07	 Cláusulas LGPD para contratos	Fase 6
08	 Política de Retenção e Descarte	Fase 6

09	 Termo de Consentimento do Titular	Fase 6
10	 Comunicação de Incidente à ANPD	Fase 7
11	 Comunicação de Incidente aos Titulares	Fase 7

GRUPO 3 • 9 MODELOS

Fichas Operacionais

12	 Termômetro — auto-diagnóstico	Preliminar
13	 Matriz de Priorização de Processos	Fase 2
14	 Ficha de Processo (Inventário)	Fase 3
15	 Ficha de Risco com matriz P × I	Fase 3
16	 GAP — Planilha de Avaliação de Controles	Fase 4
17	 Plano de Ação	Fase 5
18	 RIPD — Relatório de Impacto à Proteção de Dados	Fase 6
19	 Ficha de Operador (Terceiro)	Fase 6
20	 Registro de Solicitação DSR	Fase 6



Documentos Formais

Atos, cartas, roadmap, aviso público e plano de resposta — os documentos formais que estruturam o início e a continuidade do PGP.



Ato de Designação

do Encarregado

QUANDO USAR

No início da **Fase 1** do PGP, para cumprir o **Art. 41 da LGPD**. Documento formal que designa o Encarregado pelo Tratamento de Dados Pessoais (DPO). Deve ser publicado no diário oficial ou veículo institucional equivalente.

TEMPLATE

ATO DE DESIGNAÇÃO Nº [NÚMERO/AAAA]

(Designação do Encarregado pelo Tratamento de Dados Pessoais)

Designa o(a) Encarregado(a) pelo Tratamento de Dados Pessoais (DPO) de **[NOME DA INSTITUIÇÃO]**, em cumprimento ao art. 41 da Lei nº 13.709/2018 – Lei Geral de Proteção de Dados Pessoais (LGPD).

[A AUTORIDADE MÁXIMA – ex: O(A) PREFEITO(A) MUNICIPAL DE CIDADE], no uso de suas atribuições legais e regimentais,

CONSIDERANDO que a Lei nº 13.709/2018 (LGPD), em seu art. 41, determina ao controlador a indicação de Encarregado;

CONSIDERANDO o disposto na Resolução CD/ANPD nº 18/2024, que regulamenta a atuação do Encarregado;

CONSIDERANDO a necessidade de estabelecer canal formal de comunicação com a ANPD e com os titulares de dados pessoais;

RESOLVE:

Art. 1º Designar *[NOME DO ENCARREGADO]* como Encarregado(a) pelo Tratamento de Dados Pessoais de *[NOME DA INSTITUIÇÃO]*, nos termos do art. 41 da Lei nº 13.709/2018.

Parágrafo único. O canal de comunicação com o(a) Encarregado(a) fica estabelecido por: e-mail *[E-MAIL]*, telefone *[TELEFONE]*, atendimento presencial em *[ENDEREÇO]*.

Art. 2º A escolha do(a) Encarregado(a) considerou os seguintes fundamentos: *[JUSTIFICATIVA – perfil técnico-jurídico, autonomia, acesso à alta administração]*.

Art. 3º Compete ao(à) Encarregado(a), conforme art. 41 §2º da LGPD:

- I – aceitar reclamações e comunicações dos titulares, prestar esclarecimentos e adotar providências;
- II – receber comunicações da ANPD;
- III – orientar funcionários e contratados quanto às práticas de proteção de dados;
- IV – executar demais atribuições determinadas pelo controlador.

Art. 4º Este ato entra em vigor na data de sua publicação, revogadas as disposições em contrário.

[CIDADE], [DATA POR EXTENSO].

[NOME DA AUTORIDADE]

(Autoridade máxima do órgão)

CIENTE E DE ACORDO:

[NOME DO ENCARREGADO]

Encarregado(a) pelo Tratamento de Dados Pessoais

Designa Maria Silva Santos como Encarregada pelo Tratamento de Dados Pessoais da Prefeitura Municipal de Vegas, em cumprimento ao art. 41 da Lei nº 13.709/2018.

Justificativa: Servidora efetiva de carreira jurídica, com pós-graduação em Direito Digital, autonomia funcional e acesso direto ao gabinete.

Contatos: [\[email protected\]](#) · (00) 0000-0000 · Av. Principal, 100 — Centro.



Carta para a Alta Gestão

Patrocínio institucional ao PGP

QUANDO USAR

Na **Fase Preliminar**. Documento institucional curto apresentado ao dirigente máximo no início do trabalho de adequação. Objetivo: **obter patrocínio formal** para o programa.

TEMPLATE

À *[DESTINATÁRIO — ex: Excelentíssimo(a) Senhor(a) Prefeito(a) Municipal de Vegas]*

Assunto: Patrocínio Institucional ao Programa de Governança em Privacidade (PGP)

1. Justificativa legal

A Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018 — LGPD) está em vigor desde setembro de 2020 e é plenamente aplicável aos órgãos da Administração Pública (Art. 1º e Capítulo IV). *[NOME DA INSTITUIÇÃO]* trata, no exercício de suas atribuições legais, volume expressivo de dados pessoais de cidadãos, servidores e fornecedores — incluindo dados sensíveis. A adequação à LGPD tornou-se obrigação institucional, com responsabilização direta do(a) gestor(a) máximo(a).

2. Riscos de não-cumprimento

O não-cumprimento expõe o órgão e seus dirigentes a riscos institucionais relevantes:

- Sanções administrativas pela ANPD: advertências, publicização da infração, repercussão na imagem institucional.
- Responsabilização civil em caso de incidente (Art. 42 LGPD), com indenizações por dano moral coletivo e individual.
- Repercussão midiática e perda de confiança da população.
- Apontamentos em auditorias do Tribunal de Contas e Ministério Público.

3. Pedido

Solicitamos formalmente o apoio institucional de Vossa Excelência para a implementação do PGP de *[NOME DA INSTITUIÇÃO]*, especificamente:

- Designação formal do(a) Encarregado(a) por ato oficial (Art. 41 LGPD);
- Constituição do Comitê de Governança de Dados Pessoais, multidisciplinar;
- Alocação de recursos humanos e orçamentários compatíveis;
- Inclusão da adequação à LGPD como pauta recorrente das reuniões de gestão.

Comprometemo-nos a apresentar, no prazo de **30 (trinta) dias** após o início formal dos trabalhos, o cronograma detalhado do PGP e a lista priorizada de processos a serem mapeados.

Respeitosamente,

[NOME DO ENCARREGADO OU RESPONSÁVEL]

Encarregado(a) pelo Tratamento de Dados Pessoais

EXEMPLO PREENCHIDO

À Excelentíssima Senhora Prefeita Municipal de Vegas

A Prefeitura Municipal de Vegas trata diariamente dados de 50 mil cidadãos atendidos pela UBS, 320 estagiários por seleção, dados sensíveis de servidores. O PGP estrutura este tratamento conforme a LGPD.

Solicitamos: designação formal do Encarregado · constituição do Comitê (TI/Jurídico/Comunicação/RH/áreas) · rubrica orçamentária na LOA/2027 (~R\$ 40 mil/ano) · agenda mensal do Comitê.

Maria Silva Santos · Encarregada designada interinamente



Roadmap de 90 dias

13 marcos verificáveis

QUANDO USAR

Ao iniciar o PGP, para dar visibilidade da execução à Alta Gestão.

Cronograma de **13 semanas (~3 meses)** distribuindo as 7 Fases do PGP em marcos verificáveis. Anexar à Carta da Alta Gestão (Modelo 02).

TEMPLATE – TABELA EDITÁVEL

SEM.	FASE	ATIVIDADE-CHAVE	RESPONSÁVEL
1	Preliminar	Apresentar Carta à Alta Gestão · obter patrocínio	[a definir]
2	Fase 1	Designar Encarregado(a) · publicar no diário oficial	[a definir]
3	Fase 1	Constituir Comitê de Privacidade · 1ª reunião	[a definir]
4	Fase 2	Levantar setores · selecionar processos prioritários	[a definir]
5	Fase 2	Aplicar Matriz de Priorização Res. nº 2/2022	[a definir]

6	Fase 3	Iniciar Inventário dos 5 processos prioritários	[a definir]
7	Fase 3	Concluir Inventário · iniciar Análise de Riscos	[a definir]
8	Fase 4	Aplicar GAP Analysis (10–30 controles)	[a definir]
9	Fase 5	Consolidar Plano de Ação · aprovar no Comitê	[a definir]
10	Fase 6	Elaborar RIPD dos processos de alto risco	[a definir]
11	Fase 6	Publicar Aviso de Privacidade · canal DSR	[a definir]
12	Fase 6	Cadastrar Operadores · iniciar aditamentos	[a definir]
13	Fase 7	Estruturar PRI · apresentar PGP completo	[a definir]

💡 EXEMPLO PREENCHIDO

Sem. 1 · Preliminar · Apresentar Carta · *João Lima (Coord. Jurídico)*

Sem. 4 · Fase 2 · Levantar setores · *Maria Silva (Encarregada)*

Sem. 7 · Fase 3 · Concluir Inventário · *Maria Silva + donos de processo*

Sem. 12 · Fase 6 · Aditamentos com cláusulas LGPD · *Pedro Costa (Procuradoria)*



Aviso de Privacidade

11 seções para o cidadão

QUANDO USAR

Na **Fase 6**. Documento público publicado no portal externo. Cumpre o **Art. 9º da LGPD** (direito de informação ao titular). Recomenda-se 1 Aviso institucional + Avisos específicos para serviços de alto impacto.

TEMPLATE – AVISO INSTITUCIONAL PADRÃO

AVISO DE PRIVACIDADE — *[NOME DA INSTITUIÇÃO]*

Última atualização: *[DATA]*

1. Quem somos

[NOME DA INSTITUIÇÃO], CNPJ *[CNPJ]*, com sede em *[ENDEREÇO]*, é o controlador dos dados pessoais tratados no âmbito de suas atribuições legais.

2. Por que tratamos seus dados

Tratamos dados pessoais para *[FINALIDADES — ex: prestação de serviços públicos, atendimento ao cidadão, cumprimento de obrigações legais, execução de políticas públicas]*.

3. Quais dados tratamos

Dependendo do serviço: *[LISTA — dados cadastrais (nome, CPF), de contato (e-mail, telefone), e eventualmente dados sensíveis (ex: saúde nos atendimentos em UBS)]*.

4. Base legal do tratamento

- Cumprimento de obrigação legal ou regulatória (Art. 7º II)
- Execução de políticas públicas (Art. 7º III)
- Execução de contrato (Art. 7º V) — quando há vínculo contratual
- Quando aplicável, dados sensíveis com base no Art. 11

5. Por quanto tempo guardamos

Os prazos variam por categoria. Em geral: dados de atendimento *[X anos]*, dados de saúde *[Y anos]*, dados fiscais *[Z anos]*. Após o prazo, anonimizamos ou eliminamos.

6. Como protegemos seus dados

Controle de acesso por perfil, criptografia em trânsito, backup, logs de auditoria, treinamento da equipe. Operadores contratados têm cláusulas LGPD nos contratos.

7. Com quem compartilhamos

Apenas quando há previsão legal ou necessidade — outros órgãos públicos para execução de políticas públicas; operadores contratados sob cláusulas LGPD; autoridade judicial mediante requisição.

8. Transferência internacional

[Indicar se há ou não. Se houver, especificar país e fundamento legal (Art. 33 LGPD)].

9. Seus direitos como titular

Você pode exercer os direitos previstos no Art. 18:

- Confirmação da existência de tratamento
- Acesso aos dados tratados
- Correção, anonimização, bloqueio ou eliminação
- Portabilidade dos dados
- Informação sobre compartilhamento
- Revogação do consentimento (quando aplicável)

10. Canal de atendimento (DSR)

Encarregado(a) *[NOME DO ENCARREGADO]* — e-mail *[E-MAIL]*, telefone *[TELEFONE]*, atendimento presencial em *[ENDEREÇO]*. **Prazo de resposta: 15 dias úteis** (Art. 19 II LGPD).

11. Atualização deste Aviso

Este Aviso é revisado periodicamente. A data da última atualização aparece no topo. Mudanças significativas serão comunicadas.

💡 EXEMPLO PREENCHIDO

AVISO DE PRIVACIDADE — Prefeitura Municipal de Vegas · Última atualização: 15 de janeiro de 2027

Tratamos dados para prestação de serviços públicos municipais nas áreas de saúde, educação, assistência social, tributação e ouvidoria. Base legal: Art. 7º III (políticas públicas) e Art. 11 II 'a' em dados sensíveis de saúde.

Canal: Maria Silva (Encarregada) — [\[email protected\]](#) · (00) 0000-0000



Plano de Resposta a Incidentes

Documento do PRI • 8 seções

QUANDO USAR

Na **Fase 7**, **antes** de qualquer incidente real. Define equipe responsável (ETIR/CSIRT), matriz RACI por etapa NIST e fluxos de resposta. Sem PRI pronto, o caos do incidente impede resposta tempestiva (3 dias úteis à ANPD).

TEMPLATE — 8 SEÇÕES

§ 01 Identificação do órgão

[NOME DA INSTITUIÇÃO], CNPJ [CNPJ], com Encarregado(a) [NOME], contato [E-MAIL] / [TELEFONE].

§ 02 Objetivo do PRI

Estabelecer procedimentos padronizados para resposta a incidentes de segurança envolvendo dados pessoais, em cumprimento ao Art. 48 LGPD e à Res. CD/ANPD nº 15/2024.

§ 03 Equipe ETIR — composição mínima



DPO (Encarregado)

[NOME · E-MAIL · CELULAR 24h]



TI / Segurança

[NOME · E-MAIL · CELULAR 24h]



Jurídico

[NOME · E-MAIL · CELULAR 24h]



Comunicação

[NOME · E-MAIL · CELULAR 24h]



Alta Gestão (aprovador)

[NOME · E-MAIL · CELULAR 24h]

§ 04 **Detecção**

Canais: SIEM/logs · denúncia interna · denúncia externa · notificação de operador · auditoria. Servidor que identificar comunica imediatamente o DPO pelo canal [CANAL — e-mail dpo@ + telefone].

§ 05 **Contenção, Erradicação e Recuperação**

Contenção: isolamento do sistema, bloqueio de credencial comprometida, revogação de acesso.

Erradicação: identificação da causa-raiz, patches, fechamento da vulnerabilidade.

Recuperação: restauração de backup íntegro, monitoramento reforçado, validação.

§ 06 **Responsáveis pela comunicação**

À ANPD: elaborada pelo Encarregado + Procuradoria; aprovada pela Alta Gestão antes do envio. Prazo: **3 dias úteis**.

Aos titulares: Encarregado + Comunicação. Canal compatível com o cadastro. Prazo: **7 dias úteis** (ALTA/CRÍTICA).

§ 07 **Registro do incidente**

Todo incidente, mesmo BAIXA, deve ser registrado no sistema interno do Encarregado. Retenção mínima: 5 anos. Base legal: Art. 7º II LGPD.

§ 08 Revisão e atualização do PRI

Revisado **anualmente** OU após incidente ALTA/CRÍTICA OU mudança significativa. Recomendado: **simulado anual (tabletop)** com cenário plausível.

💡 EXEMPLO PREENCHIDO

Prefeitura Municipal de Vegas · Encarregada: Maria Silva — [\[email protected\]](#) · (00) 0000-0001

ETIR: DPO Maria Silva (primário) · TI João Costa (24h) · Procuradoria-Geral (Dr. Pedro) · Alta Gestão (Prefeita Ana)

Última simulação tabletop: 12/03/2026 — cenário "pendrive perdido com 500 prontuários". Resultado: 18h até comunicação ANPD (dentro do prazo).

GRUPO 2 · 6 MODELOS



Documentos Institucionais

Políticas, cláusulas contratuais, termos e comunicações oficiais — os documentos que estruturam a governança e a resposta institucional.



Política do PGP

Documento mater • 8 seções

QUANDO USAR

Na **Fase 5**. Documento institucional aprovado por ato formal do dirigente máximo. Cita os demais instrumentos do PGP como anexos vinculados.

Revisão anual recomendada.

TEMPLATE – 8 SEÇÕES

1. Objetivo

Esta Política estabelece o PGP de *[NOME DA INSTITUIÇÃO]*, em cumprimento à LGPD, regulamentando o tratamento de dados pessoais no âmbito de suas atividades.

2. Abrangência

Aplica-se a todas as unidades, servidores, estagiários, terceirizados e demais agentes que realizem tratamento de dados pessoais sob qualquer forma e base legal.

3. Princípios

Observa os princípios do Art. 6º da LGPD: finalidade, adequação, necessidade, livre acesso, qualidade, transparência, segurança, prevenção, não discriminação

e responsabilização.

4. Governança

Conduzido pelo(a) Encarregado(a) **[NOME]**, designado(a) por ato formal (Art. 41), com apoio do Comitê de Privacidade — instância multidisciplinar (TI, Jurídico, Comunicação, RH, áreas de negócio). Comitê reúne-se **[PERIODICIDADE]**.

5. Instrumentos do PGP

Integram o PGP, como anexos vinculados:

- (a) Inventário de Tratamentos · (b) Análise de Riscos · (c) Análise de Conformidade (GAP) · (d) Plano de Ação
- (e) RIPDs dos processos de alto risco · (f) Cadastro de Operadores com cláusulas LGPD
- (g) Canal DSR · (h) Aviso de Privacidade público · (i) Plano de Resposta a Incidentes

6. Responsabilidades

Dirigente máximo: aprova, garante recursos, responde por sanções (Art. 52).

Encarregado: conduz operacionalmente, comunica-se com ANPD e titulares.

Comitê: delibera estrategicamente.

Gestores de área: aplicam as orientações.

Servidores: cumprem políticas, reportam incidentes.

Operadores: cumprem cláusulas LGPD dos contratos.

7. Revisão

Revisada anualmente ou antes em caso de: alteração legislativa · decisão da ANPD · incidente ALTA/CRÍTICA · reorganização institucional relevante.

8. Vigência

Entra em vigor na data de sua publicação em **[DIÁRIO OFICIAL]** e revoga disposições em contrário.

💡 EXEMPLO PREENCHIDO

POLÍTICA DO PGP — Prefeitura Municipal de Vegas

Encarregada: Maria Silva (Procuradoria-Adjunta). Comitê: 7 membros (TI/Jurídico/Comunicação/RH/Saúde/Tributário/Assistência Social).

Reuniões mensais na 1ª terça-feira do mês.

Aprovado pelo Decreto Municipal nº 042/2027, de 15 de fevereiro de 2027 —
Prefeita Ana Costa.



Cláusulas LGPD para contratos

Aditamento padrão · 8 cláusulas · Art. 39

QUANDO USAR

Para incluir em contratos novos OU aditar contratos vigentes com operadores. Atende o **Art. 39 LGPD**. Em contratos antigos pré-2020 sem cláusulas LGPD, promover aditamento gradualmente.

TEMPLATE – 8 CLÁUSULAS MÍNIMAS

CLÁUSULA 1 **Objeto do tratamento**

O OPERADOR realizará tratamento de dados pessoais exclusivamente para os fins descritos no objeto principal deste contrato, ficando vedado qualquer tratamento estranho a esse escopo, salvo expressa autorização prévia e por escrito da CONTRATANTE.

CLÁUSULA 2 **Segurança e confidencialidade**

O OPERADOR adotará medidas técnicas e administrativas adequadas para proteger os dados pessoais contra acessos não autorizados, perdas acidentais, alterações indevidas ou divulgação inadequada, em conformidade com os Arts. 46 a 49 da LGPD.

CLÁUSULA 3 **Comunicação de incidentes**

O OPERADOR comunicará à CONTRATANTE, imediatamente após o conhecimento e em prazo não superior a **24 (vinte e quatro) horas**, qualquer incidente de segurança envolvendo dados pessoais sob seu tratamento, fornecendo informações para subsidiar a comunicação à ANPD e aos titulares.

CLÁUSULA 4 **Subcontratação**

O OPERADOR não subcontratará terceiros sem prévia autorização escrita. Em caso de autorização, o sub-operador assumirá as mesmas obrigações por instrumento escrito.

CLÁUSULA 5 **Direitos dos titulares**

O OPERADOR auxiliará a CONTRATANTE no atendimento das solicitações dos titulares (Art. 18 LGPD), em prazo não superior a **5 (cinco) dias úteis** a contar da requisição.

CLÁUSULA 6 **Retenção e devolução/destruição**

Encerrada a relação contratual, o OPERADOR devolverá ou destruirá todos os dados pessoais em prazo não superior a **30 (trinta) dias**, salvo determinação legal em contrário.

CLÁUSULA 7 **Auditoria**

A CONTRATANTE poderá, mediante aviso prévio de 15 dias úteis, realizar auditoria das medidas de segurança implementadas, diretamente ou por terceiro independente.

CLÁUSULA 8 **Responsabilidade**

O OPERADOR responde civilmente pelos danos decorrentes do descumprimento (Art. 42 LGPD), sem prejuízo das sanções administrativas e judiciais cabíveis.

Promover **TERMO ADITIVO** ao contrato, sem necessidade de rescisão.

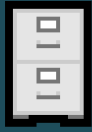
Cabeçalho: "*Termo Aditivo nº X — Inclusão de Cláusulas LGPD ao Contrato nº Y*". Anexar este conjunto de 8 cláusulas. Assinatura de ambas as partes.

 EXEMPLO PREENCHIDO

TERMO ADITIVO Nº 02 — Inclusão de Cláusulas LGPD ao Contrato nº 045/2024

Pelo presente Termo, a Prefeitura Municipal de Vegas e a Empresa Hipotética Tecnologia LTDA (CNPJ 00.000.000/0001-00) aditam o Contrato nº 045/2024 (objeto: hospedagem do sistema de Ouvidoria) para incluir as Cláusulas LGPD do Art. 39 da Lei 13.709/2018.

Vegas, 15 de março de 2027. Prefeita Ana Costa / Diretor Empresa Hipotética.



Política de Retenção e Descarte

Prazos por categoria · Art. 16

QUANDO USAR

Na **Fase 6**. Define prazos de retenção por categoria de dado e procedimento de descarte seguro. Cumpre o **Art. 16 da LGPD**. Revisão anual recomendada.

TEMPLATE

1. Princípio geral

Os dados pessoais não são mantidos por tempo superior ao necessário ao cumprimento da finalidade. Findo o tratamento, devem ser eliminados, anonimizados ou ter retenção justificada em hipótese legal específica.

2. Hipóteses que autorizam retenção (Art. 16)

- Cumprimento de obrigação legal ou regulatória
- Estudo por órgão de pesquisa (com anonimização sempre que possível)
- Transferência a terceiro respeitada a Lei
- Uso exclusivo do controlador, com anonimização

3. Tabela de prazos por categoria

Dados de servidores ativos	<i>[durante vínculo + até 75 anos]</i>
Servidores inativos / pensionistas	<i>[prazos previdenciários]</i>
Candidatos não selecionados	<i>[1 ano após validade do edital]</i>
Atendimento / Ouvidoria	<i>[5 anos – prescricional padrão]</i>
Dados de saúde (prontuários)	<i>[20 anos • CFM 1.821/2007]</i>
Dados fiscais / tributários	<i>[5 anos]</i>
Logs de acesso a sistemas	<i>[6 meses a 5 anos]</i>
Imagens de CFTV	<i>[30 a 90 dias]</i>
Licitantes não vencedores	<i>[5 anos após encerramento]</i>

4. Procedimento de descarte

Documental: fragmentação ou incineração com registro em termo.

Digital: exclusão lógica + sobrescrita ou descarte físico do meio.

Em ambos: lavrar termo de descarte com data, responsável e categoria. Reter o termo pelo prazo prescricional aplicável.

5. Anonimização como alternativa

Quando viável, anonimizar em vez de descartar (Art. 12 LGPD) — dado anonimizado sai do escopo da LGPD. Anonimização precisa ser **irreversível** (não basta pseudonimização).

6. Revisão

Revisada anualmente para adequar prazos a alterações legislativas e novos sistemas implantados.

💡 EXEMPLO PREENCHIDO

POLÍTICA DE RETENÇÃO — Prefeitura Municipal de Vegas

Dados de servidores ativos: durante o vínculo + 75 anos (Lei nº 9.717/1998).

Dados de Ouvidoria: 5 anos (prazo prescricional padrão).

Prontuários médicos: 20 anos da última consulta (CFM 1.821/2007).

Anonimização aplicada aos dados de saúde após 20 anos (estatística agregada).



Termo de Consentimento

Apenas tratamentos facultativos

⚠ ATENÇÃO — QUANDO USAR

APENAS em tratamentos FACULTATIVOS do ponto de vista do cidadão (newsletter voluntária, autorização para uso de imagem em material promocional). No setor público, consentimento é base legal **EXCEPCIONAL** — a regra é Art. 7º II ou Art. 7º III. Exige possibilidade **REAL** de recusa sem prejuízo do serviço público.

📄 TEMPLATE

TERMO DE CONSENTIMENTO PARA TRATAMENTO DE DADOS PESSOAIS

[NOME DA INSTITUIÇÃO], CNPJ [CNPJ], sede em [ENDEREÇO], na qualidade de Controlador (Art. 5º VI LGPD), solicita o consentimento de [NOME DO TITULAR] para o tratamento dos seguintes dados pessoais:

DADOS TRATADOS

[LISTA — ex: nome, e-mail, telefone, imagem]

FINALIDADE

[ex: envio de informativo institucional
mensal sobre eventos culturais]

PRAZO DE RETENÇÃO

[ex: até descadastro pelo titular]

COMPARTILHAMENTOS

[se houver — especificar]

Direitos do titular

O titular pode, a qualquer tempo, **revogar este consentimento** e exercer os direitos do Art. 18 da LGPD (acesso, correção, anonimização, eliminação, portabilidade, oposição, informações sobre compartilhamento), pelo canal: **[E-MAIL DO ENCARREGADO]**.

Declaração

Declaro ter sido informado(a) sobre o tratamento dos meus dados pessoais e concordo livremente, de forma específica e inequívoca (Art. 5º XII LGPD), com o tratamento descrito acima.

Local, data: **[CIDADE]**, **[DATA]**.

Assinatura do(a) titular

✗ VALIDADE DO CONSENTIMENTO

Consentimento marcado por padrão (**opt-out**) é INVÁLIDO (Art. 8º). A caixa de aceite deve estar **desmarcada por padrão** — o titular marca se quiser (**opt-in real**). Pode ser revogado a qualquer momento pelo canal DSR.

💡 EXEMPLO PREENCHIDO

TERMO DE CONSENTIMENTO — Prefeitura Municipal de Vegas

Dados: nome + e-mail. **Finalidade:** envio de newsletter mensal sobre eventos culturais. **Prazo:** até descadastro. **Compartilhamento:** nenhum.

Titular: João Silva. **Canal DSR:** [\[email protected\]](#).

10

GRUPO 2 · DOCUMENTO INSTITUCIONAL · FASE 3d



Comunicação à ANPD

Incidente · 10 campos obrigatórios

QUANDO USAR

Em até **3 dias úteis** após o conhecimento de incidente de severidade **ALTA** ou **CRÍTICA** (Art. 48 LGPD + Res. CD/ANPD nº 15/2024). Submeter via portal: **gov.br/anpd** → **Comunicações**.

TEMPLATE — CAMPOS OBRIGATÓRIOS

1. Identificação do controlador

Nome do órgão	[NOME DA INSTITUIÇÃO]
CNPJ	[CNPJ]
Endereço	[ENDEREÇO COMPLETO]
Nome do Encarregado	[NOME DO ENCARREGADO]
E-mail · Telefone	[E-MAIL] · [TELEFONE]

2. Quando ocorreu / foi detectado

Ocorrência	[DATA + HORA — ou "desconhecida"]
Deteção	[DATA + HORA]
Esta comunicação	[DATA + HORA]

3. Descrição do incidente

[DESCRIÇÃO OBJETIVA — vazamento por acesso indevido? perda de dispositivo? ataque externo? falha em sistema?]

4. Natureza dos dados afetados

- ☐ Dados cadastrais (nome, CPF, RG, endereço)
- ☐ Dados de contato (e-mail, telefone)
- ☐ Dados financeiros (conta bancária, salário)
- ☐ Dados de saúde
- ☐ Outros dados sensíveis (Art. 5º II) — especificar
- ☐ Dados de crianças/adolescentes
- ☐ Outros — especificar

5. Categorias e número de titulares

Categorias *[ex: servidores ativos, cidadãos atendidos]*

Nº aproximado *[ex: 250 servidores]*

6. Medidas de segurança em uso

[Medidas que existiam ANTES do incidente — controle de acesso, criptografia, backup, treinamento]

7. Riscos relacionados

[Análise dos riscos — danos morais aos titulares, exposição financeira, discriminação, etc.]

8. Medidas adotadas para mitigar

- ☐ Isolamento do sistema/processo afetado
- ☐ Revogação de credenciais comprometidas
- ☐ Aplicação de patches/correções
- ☐ Restauração a partir de backup íntegro
- ☐ Apuração disciplinar (se aplicável)
- ☐ Notificação individual aos titulares afetados

- ☐ Revisão dos perfis de acesso
- ☐ Outras — especificar

9. Motivo do atraso (se aplicável)

[Se a comunicação não foi em até 3 dias úteis — justificar com base técnica/operacional]

10. Responsável pela comunicação

Nome *[NOME DO ENCARREGADO]*
Cargo *[CARGO]*
Data, cidade, assinatura *[DATA], [CIDADE]*

EXEMPLO PREENCHIDO

Comunicação à ANPD — Incidente de 15/03/2027

Controlador: Prefeitura Municipal de Vegas. Encarregada: Maria Silva — [\[email protected\]](#).

Deteção: 18/03/2027 — auditoria identificou cópia local não-autorizada de planilha contendo dados de 250 servidores (CPF, conta bancária).

Mitigação: acesso do servidor revogado em 30 min · planilha excluída · apuração instaurada · 250 titulares notificados em até 7 dias úteis.

Encarregada Maria Silva — comunicação submetida em 20/03/2027 às 16h.



Comunicação aos Titulares

Incidente · linguagem clara · 7 dias úteis

QUANDO USAR

Em até **7 dias úteis** após o conhecimento de incidente **ALTA ou CRÍTICA** (Art. 48 LGPD + Res. 15/2024). Comunicar pelo canal mais compatível com o cadastro do titular (e-mail, carta, SMS, telefone).

TEMPLATE — MODELO DE CARTA/E-MAIL

Prezado(a) *[NOME DO TITULAR]*,

Em cumprimento ao dever de transparência previsto na Lei Geral de Proteção de Dados Pessoais — LGPD (Lei nº 13.709/2018, Art. 48), comunicamos a ocorrência de incidente de segurança envolvendo dados pessoais sob nossa responsabilidade que afetou dados de sua titularidade.

O que aconteceu

Em *[DATA DA OCORRÊNCIA]*, identificamos *[DESCRIÇÃO BREVE — linguagem clara, sem jargão. Ex: "acesso não autorizado a uma planilha contendo dados pessoais de servidores municipais"]*.

Quais dados seus foram afetados

Os dados envolvidos, referentes a você, foram: *[LISTAR DADOS ESPECÍFICOS — ex: nome completo, CPF, dados bancários]*.

O que estamos fazendo

Adotamos as seguintes medidas para mitigar o ocorrido e evitar novos incidentes: *[LISTAR MEDIDAS — ex: "revogamos imediatamente o acesso indevido", "instauramos procedimento de apuração", "revisamos os perfis de acesso", "comunicamos à ANPD"]*.

O que você pode fazer

Recomendamos que você, como medida preventiva, considere:

- Monitorar movimentações em suas contas bancárias e cadastros (se aplicável)
- Manter atenção a tentativas de fraude que possam usar essas informações
- Entrar em contato conosco em caso de dúvidas ou suspeitas

Como falar conosco

O(A) Encarregado(a) *[NOME]* está disponível para esclarecer dúvidas:

E-mail: *[E-MAIL]*

Telefone: *[TELEFONE]*

Atendimento presencial: *[ENDEREÇO]*

Reiteramos nosso compromisso com a proteção de seus dados pessoais.

Respeitosamente,

[NOME DO ENCARREGADO]

Encarregado(a) pelo Tratamento de Dados Pessoais

[NOME DA INSTITUIÇÃO]

EXEMPLO PREENCHIDO

Prezada Sra. Joana da Silva,

Em 15/03/2027 identificamos acesso não autorizado a planilha contendo dados de servidores municipais. Os dados afetados, referentes a você, foram: nome completo, CPF, conta bancária utilizada para recebimento de salário.

Medidas: revogamos o acesso em 30 minutos · planilha removida · apuração instaurada · ANPD comunicada em 3 dias úteis.

Recomendamos monitorar sua conta bancária. Dúvidas: Maria Silva
(Encarregada) — [\[email protected\]](#) · (00) 0000-0001. Prefeitura Municipal de
Vegas.

GRUPO 3 · 9 MODELOS



Fichas Operacionais

Formulários para o dia a dia do PGP — diagnóstico, inventário,
riscos, GAP, plano, RIPD e cadastros operacionais.



Termômetro

Auto-diagnóstico — você + sua Instituição

QUANDO USAR

Na **Fase Preliminar**, como linha de base, e periodicamente (semestral/anual) para evidenciar a evolução. **2 blocos com scores separados**: Parte 1 mede conhecimento individual; Parte 2 mede a maturidade institucional (uma pergunta por etapa do PGP).

PARTE 1 — SOBRE VOCÊ (3 PERGUNTAS)



Qual o seu contato com a LGPD até hoje?

- | | |
|--|---|
| ☐ Nunca ouvi falar (5) | ☐ Já ouvi falar (10) |
| ☐ Conheço o básico (15) | ☐ Conheço bem (20) |



No seu trabalho, você saberia dizer o que pode e o que não pode fazer com dados de pessoas?

- | | |
|--|---|
| ☐ Ainda não saberia (5) | ☐ Só intuição (10) |
| ☐ Sei o essencial (15) | ☐ Sei com segurança (20) |



Se acontecer um problema com dados pessoais (vazamento, reclamação), você sabe o que fazer?

☐ Não faria ideia (5)

☐ Avisaria o chefe (10)

☐ Sei os primeiros passos (15)

☐ Sei o procedimento (20)

Score pessoal (0-100) = soma dos pontos ÷ 60 × 100 = [SCORE]

PARTE 2 – SOBRE A SUA INSTITUIÇÃO (7 PERGUNTAS)



Os chefes compram a ideia de proteger dados?

↳ Fase Preliminar

☐ Não olham pra isso (5)

☐ Acham importante (10)

☐ Apoiam oficialmente (15)

☐ Puxam o tema (20)



Tem alguém responsável por proteção de dados?

↳ Fase 1

☐ Ninguém ainda (5)

☐ Alguém informal (10)

☐ Nomeado oficialmente (15)

☐ Responsável + equipe (20)



Vocês sabem quais dados o órgão usa e onde ficam?

↳ Fase 2

☐ Ainda não levantamos (5)

☐ Só uma noção (10)

☐ Principais mapeados (15)

☐ Mapa completo (20)



Vocês avaliam riscos antes de usar dados delicados?

↳ Fase 3

☐ Sem esse hábito (5)

☐ Só quando salta aos olhos (10)

☐ Nos casos delicados (15)

☐ Método padrão (20)



Já compararam o que fazem com o que a Lei exige?

↳ Fase 4

☐ Não sabemos o que falta (5)

☐ Ideia geral (10)

☐ Levantamento feito (15)

☐ Lista priorizada (20)



Existe um plano com prazos — e ele sai do papel?

↳ Fases 5 e 6

- | | |
|---|---|
| ☐ Sem plano ainda (5) | ☐ Boas intenções (10) |
| ☐ Plano escrito (15) | ☐ Em execução (20) |



Depois de ajustar, vocês acompanham e revisam?

↳ Fase 7

- | | |
|--|--|
| ☐ Não revisamos (5) | ☐ Só quando dá problema (10) |
| ☐ Revisão combinada (15) | ☐ Com indicadores (20) |

Score institucional (0-100) = soma dos pontos ÷ 140 × 100 = [SCORE]

Faixas do score pessoal (conhecimento)

- | | |
|---------------|--|
| 80-100 | Multiplicador — Domínio forte; pode orientar colegas. |
| 60-79 | Bom domínio — Navega bem pelo tema no dia-a-dia. |
| 40-59 | Conhecimento em construção — Base formada; faltam conexões. |
| 20-39 | Conhecimento inicial — Já ouviu os termos; agora é organizar. |
| 0-19 | Primeiro contato — Você está começando agora. |

Faixas do score institucional (maturidade)

- | | |
|---------------|--|
| 80-100 | Maturidade Avançada — Órgão referência; cultura forte. |
| 60-79 | Maturidade Estabelecida — Boa base; faltam consolidações. |
| 40-59 | Em Desenvolvimento — Caminho iniciado; precisa estruturar mais. |
| 20-39 | Maturidade Inicial — Pontos de partida identificados. |

 EXEMPLO PREENCHIDO

Aplicação em 15/01/2027 — servidor(a) da Prefeitura Municipal de Vegas:

Parte 1 (você): $10 + 10 + 5 = 25$ pontos $\rightarrow 25 \div 60 \times 100 =$ **score pessoal 42/100**

— Conhecimento em construção.

Parte 2 (instituição): 50 pontos $\rightarrow 50 \div 140 \times 100 =$ **score institucional 36/100**

— Maturidade Inicial.

Reaplicar em 6 meses para acompanhar a evolução.

13

GRUPO 3 · FICHA OPERACIONAL · FASE 2



Matriz de Priorização

Res. CD/ANPD nº 2/2022 · 6 critérios



QUANDO USAR

Na **Fase 2**, para priorizar quais processos entram primeiro no Inventário detalhado da Fase 3. Aplicar a cada processo. **Score 0–18** (1–3 pontos por critério × 6 critérios).

FORMULÁRIO — POR PROCESSO

PROCESSO AVALIADO

[NOME DO PROCESSO]



Volume de titulares

Baixo 1 = até 100 · Médio 2 = 100–1.000 · Alto 3 = +1.000



Sensibilidade dos dados

Baixo 1 = cadastrais · Médio 2 = financeiros, comportamentais · Alto 3 = sensíveis (Art. 5º II)



Vulnerabilidade dos titulares

Baixo 1 = adultos · Médio 2 = vulneráveis eventualmente · Alto 3 = sistematicamente menores/idosos



Exposição pública

Baixo 1 = restrito · Médio 2 = compartilhamento limitado · Alto 3 = publicação ampla



Tecnologias inovadoras

Baixo 1 = planilhas · Médio 2 = sistemas convencionais · Alto 3 = IA, biometria, decisões automatizadas



Compartilhamentos com terceiros

Baixo 1 = nenhum/interno · Médio 2 = 1-2 operadores · Alto 3 = múltiplos ou transferência internacional

Score total = [SOMA 0-18]

■ 0-6 BAIXA ■ 7-12 MÉDIA ■ 13-18 ALTA

RANKING DOS PROCESSOS

Após pontuar todos os processos, ordenar do maior score para o menor. Os **5-10 primeiros** entram no Inventário detalhado da Fase 3.

EXEMPLO PREENCHIDO

Processo: Atendimento no Posto de Saúde Dr. Joaquim Bento

Volume 3 (Alto · ~24mil/ano) · Sensibilidade 3 (saúde) · Vulneráveis 2 (idosos eventualmente) · Exposição 1 (restrito) · Tecnologias 2 (sistema convencional) · Compartilhamentos 2 (ESUS-DAB federal)

Score: 13/18 = ALTA prioridade.

Justificativa: alto volume + dados de saúde sensíveis. Entra como prioridade nº 1 no Inventário.



Ficha de Processo

Inventário • 1 ficha por processo

QUANDO USAR

Na **Fase 3**, para cada processo de tratamento mapeado. Documenta o ciclo completo: titulares, dados, finalidade, base legal, retenção, compartilhamentos, medidas. **Reproduzir 1 ficha por processo.**

FORMULÁRIO

NOME DO PROCESSO

[NOME — ex: Atendimento no Posto de Saúde]

SETOR RESPONSÁVEL

[SETOR — ex: Secretaria Municipal de Saúde]

DONO DO PROCESSO

[CARGO — ex: Gerente do Posto Central]

CATEGORIAS DE TITULARES

[cidadãos atendidos • responsáveis de menores • servidores]

TIPOS DE DADOS COLETADOS

[lista granular — nome, CPF, endereço, telefone, prontuário, prescrições]

DADOS SENSÍVEIS?	[Sim/Não — se sim, listar quais: saúde / opinião política / etc.]
FINALIDADE	[descrição clara e específica]
BASE LEGAL	[ex: Art. 7º III + Art. 11 II 'a' (saúde)]
COMO COLETADOS	[formulário físico + cadastro no sistema Saúde+]
ONDE ARMAZENADOS	[sistema Saúde+ + arquivo físico de fichas]
QUEM TEM ACESSO	[perfis: médico, enfermeiro, recepção, gestor]
COMPARTILHAMENTOS INTERNOS	[outros setores do órgão que recebem]
COMPARTILHAMENTOS EXTERNOS	[empresas contratadas, outros órgãos — com cláusulas LGPD]
PRAZO DE RETENÇÃO	[ex: 20 anos da última consulta — CFM 1.821/2007]
PROCEDIMENTO DE DESCARTE	[anonimização após 20 anos / fragmentação física]
MEDIDAS TÉCNICAS	[login individual + perfil + logs + backup criptografado]
MEDIDAS ADMINISTRATIVAS	[treinamento anual obrigatório, termo individual]
APROVADO PELO DPO EM	[DATA — após revisão]

Processo: Atendimento no Posto de Saúde Dr. Joaquim Bento · **Setor:** SMS ·

Dono: Dra. Ana (Gerente)

Titulares: cidadãos atendidos (~24mil/ano) + responsáveis de menores. **Dados:** cadastrais + sensíveis de saúde (prontuário, prescrições, exames).

Base legal: Art. 7º III (políticas públicas — SUS) + Art. 11 II 'a' (tutela da saúde).

Sistema Saúde+ (DC municipal) + prontuário físico. Acesso por perfil.

Retenção: 20 anos da última consulta. **Descarte:** anonimização agregada para estatística + fragmentação dos físicos.

Aprovado por Maria Silva (Encarregada) em 15/04/2027.



Ficha de Risco

Matriz Probabilidade × Impacto

QUANDO USAR

Na **Fase 3**, junto do Inventário. Para cada processo, identificar **2–4 riscos principais**. Classificar Probabilidade × Impacto na matriz 3×3.

FORMULÁRIO

RISCO – TÍTULO CURTO

[NOME — ex: Acesso indevido por servidor sem necessidade]

PROCESSO RELACIONADO

[NOME DO PROCESSO]

CATEGORIA

[Confidencialidade / Integridade / Disponibilidade / Finalidade / Outro]

DESCRIÇÃO (CENÁRIO CONCRETO)

[Quem faz o quê, com qual consequência ao titular]

PROBABILIDADE

[BAIXA / MÉDIA / ALTA]

IMPACTO

[BAIXO / MÉDIO / ALTO]

SEVERIDADE RESULTANTE

[Da matriz 3×3 — BAIXO / MÉDIO / ALTO]

MITIGAÇÃO PROPOSTA

[Ações concretas para reduzir
probabilidade ou impacto]

RESPONSÁVEL

[NOME ou setor]

PRAZO DE IMPLEMENTAÇÃO

[DATA esperada]

**RISCO RESIDUAL APÓS
MITIGAÇÃO**

[BAIXO / MÉDIO (aceitável) · ALTO = exige
escalada]

Matriz 3×3 de referência

	Impacto BAIXO	Impacto MÉDIO	Impacto ALTO
Prob. ALTA	MÉDIO	ALTO	ALTO
Prob. MÉDIA	BAIXO	MÉDIO	ALTO
Prob. BAIXA	BAIXO	BAIXO	MÉDIO

💡 EXEMPLO PREENCHIDO

Risco: Acesso indevido à folha por servidor não-autorizado · **Processo:** Folha de Pagamento · **Categoria:** Princípio da finalidade.

Cenário: servidor com acesso amplo consulta dados de colegas por curiosidade.

Probabilidade ALTA × Impacto MÉDIO = Severidade ALTA.

Mitigação: revisão de perfis (menor privilégio) · logs de consulta · auditoria trimestral · treinamento + termo individual.



GAP — Avaliação de Controles

Aderente • Parcial • Não Aderente

QUANDO USAR

Na **Fase 4**. Para cada controle do catálogo, a Instituição se classifica em **ADERENTE / PARCIAL / NÃO ADERENTE** com justificativa. Cada NÃO ADERENTE vira ação no Plano (Fase 5).

FORMULÁRIO — POR CONTROLE

ID DO CONTROLE

[1–30 do pacote ou catálogo institucional]

TEXTO DO CONTROLE

[ex: Encarregado designado por ato formal e publicado]

ÁREA / FASE DO PGP

[ex: Fase 1 — Governança]

CLASSIFICAÇÃO

☒ ADERENTE

☐ PARCIAL

☒ NÃO ADERENTE

☐ APOIO PENDENTE

JUSTIFICATIVA

[Explicação técnica/objetiva da classificação]

EVIDÊNCIAS

[Documentos, sistemas, processos que comprovam]

SETOR DE APOIO (SE APOIO PENDENTE)

[TI / Jurídico / Comunicação / RH]

AVALIADO POR

[NOME do Encarregado ou Comitê]

DATA DA AVALIAÇÃO

[DATA]

Pontuação consolidada do GAP

Score = $((\text{aderentes} \times 100) + (\text{parciais} \times 50)) / (\text{total avaliado} \times 100)$

Avaliados = aderentes + parciais + não-aderentes (APOIO PENDENTE não conta no denominador)

≥ 80%

Maturidade alta

60-79

Média

40-59

Em construção

< 40%

Inicial

💡 EXEMPLO PREENCHIDO

Controle 04 (Fase 1) · Encarregado designado por ato formal · **ADERENTE** ·

Justificativa: Portaria nº 03/2026 publicada no DOM-Vegas em 15/03/2026 ·

Evidências: cópia da Portaria + contatos no portal · Avaliado por Maria Silva em 20/04/2027.

Controle 22 (Fase 6) · Cláusulas LGPD em contratos · **NÃO ADERENTE** ·

Justificativa: 30 contratos vigentes; só 5 têm cláusulas. Aditamento em andamento · Vira ação no Plano (prazo 90 dias).



Plano de Ação

Responsável nomeado · prazo concreto · indicador medível

QUANDO USAR

Na **Fase 5**. Cada controle NÃO ADERENTE do GAP + cada risco ALTO vira uma ação no Plano. Acompanhamento **mensal** pelo Comitê de Privacidade.

FORMULÁRIO — POR AÇÃO

AÇÃO

[Descrição clara e específica do que será feito]

ORIGEM

[GAP / RISCO / DIAGNÓSTICO / MANUAL]

REFERÊNCIA (ID)

[ID do controle GAP ou risco que originou]

RESPONSÁVEL

[NOME e/ou SETOR responsável]

PRIORIDADE

BAIXA

MÉDIA

ALTA

PRAZO

[DATA esperada]

STATUS ATUAL

[ABERTA / EM ANDAMENTO / CONCLUÍDA]

EVIDÊNCIA DE CONCLUSÃO

[Preencher quando concluída]

OBSERVAÇÕES

[Bloqueios, dependências, decisões do Comitê]

Boas práticas do Plano

- ✓ Cada ação com **responsável nomeado** (não setor genérico). Sem nome, não anda.
- ✓ Prazo **realista** — não defina prazos heróicos que ninguém vai cumprir.
- ✓ Acompanhamento **mensal** pelo Comitê — pauta fixa de revisão.
- ✓ Ações concluídas devem ser **arquivadas** (não excluídas) — vira histórico institucional.
- ✓ Ações com **mais de 3 meses sem progresso** → reavaliar viabilidade ou repriorizar.

💡 EXEMPLO PREENCHIDO

Ação: Promover aditivo contratual com cláusulas LGPD em 30 contratos vigentes pré-2020.

Origem: GAP (controle 22). **Responsável:** Pedro Costa (Procuradoria).

Prioridade ALTA. Prazo: 90 dias. **Status:** EM ANDAMENTO (10/30 concluídos).

Observação: priorizar contratos com operadores que tratam dados sensíveis ou em larga escala.



RIPD

Relatório de Impacto à Proteção de Dados • 8 seções

QUANDO USAR

Na **Fase 6**, para processos de **ALTO RISCO** (Art. 38 LGPD): dados sensíveis em larga escala, vigilância sistemática, decisões automatizadas, dados de crianças/adolescentes, tecnologias inovadoras. **Reproduzir 1 RIPD por processo crítico.**

TEMPLATE — 8 SEÇÕES

RIPD — *[NOME DO PROCESSO]*

§ 01 Identificação do controlador e do Encarregado

Controlador: *[NOME DA INSTITUIÇÃO]*, CNPJ *[CNPJ]*. Encarregado(a): *[NOME]*, contatos *[E-MAIL/TELEFONE]*. Operadores envolvidos: *[LISTAR — com referência aos contratos]*.

§ 02 Descrição do tratamento e finalidades

[Natureza do tratamento, finalidades específicas, categorias de titulares, fluxos de dados (origem → tratamento → destino)].

§ 03 **Necessidade e proporcionalidade**

[Por que os dados tratados são os estritamente necessários? Há alternativa menos invasiva que cumpra a mesma finalidade?]

§ 04 **Riscos identificados aos titulares**

[Vazamento por acesso indevido, uso para fim incompatível, decisão automatizada equivocada, discriminação, etc.]

§ 05 **Medidas de segurança e mitigação**

[Técnicas (criptografia, controle de acesso, logs, backup) + administrativas (treinamento, termo de responsabilidade, política interna)].

§ 06 **Mecanismos para exercício de direitos**

Canal DSR para este processo: *[E-MAIL/FORMULÁRIO/TELEFONE]*. **Prazo: 15 dias úteis** (Art. 19 II LGPD). Documentar como cada direito do Art. 18 é atendido.

§ 07 **Decisão e responsabilidades**

[O tratamento é aprovado? Sim/Não/Condicional. Quais condições? Quem assina? Responsabilidades dos atores envolvidos (DPO, dono do processo, TI, operadores)].

§ 08 **Revisão e atualização**

Revisado em *[PRAZO — recomendado anual]* ou antes em caso de: mudança no fluxo · novo sistema · novo operador · alteração legislativa · incidente relevante.

[CIDADE], [DATA].

[NOME DO ENCARREGADO]

Encarregado(a) pelo Tratamento de Dados Pessoais

RIPD — Atendimento no Posto de Saúde Dr. Joaquim Bento

Controlador: PM Vegas. Encarregada: Maria Silva. Operadores: empresa de TI hospedando o sistema Saúde+ (contrato 022/2024 com cláusulas LGPD).

Tratamento: prontuário eletrônico, agendamento, exames. ~24mil titulares/ano, dados sensíveis de saúde.

Riscos: vazamento por acesso indevido · acesso por servidor sem necessidade · perda do banco em falha técnica.

Mitigação: login individual + segregação por perfil + logs + backup criptografado + treinamento + termo individual.

Aprovado pela Encarregada em 20/05/2027. **Próxima revisão:** 20/05/2028.



Ficha de Operador

Terceiro • cadastro centralizado

QUANDO USAR

Na **Fase 6**, para cada operador (terceiro que trata dados em nome da Instituição). Mantém registro centralizado dos contratos com cláusulas LGPD e do nível de risco. **Reproduzir 1 ficha por operador.**

FORMULÁRIO

NOME DO OPERADOR

[NOME DA EMPRESA/ÓRGÃO]

CNPJ

[CNPJ]

SERVIÇO PRESTADO

[ex: hospedagem do sistema de ouvidoria]

PAPEL LGPD

[OPERADOR / CONTROLADOR CONJUNTO]

CONTRATO N°

[NÚMERO/ANO]

OBJETO DO CONTRATO

[DESCRIÇÃO RESUMIDA]

VIGÊNCIA

[DATA INÍCIO — DATA FIM]

CLÁUSULAS LGPD?

SIM

NÃO

EM ADITAMENTO

TIPO DE OPERAÇÃO

[CONTRATO_NOVO_CLAUSULAS /
RENOVACAO_ADITIVAR /
ADITIVO_NECESSARIO]

NÍVEL DE RISCO

BAIXO

MÉDIO

ALTO

CRITÉRIOS DO NÍVEL DE RISCO

[Critérios da Res. CD/ANPD nº 2/2022
aplicáveis]

DADOS PESSOAIS TRATADOS

[CATEGORIAS — cadastrais, sensíveis,
financeiros, etc.]

VOLUME DE TITULARES

[ESTIMATIVA]

SUBCONTRATAÇÃO AUTORIZADA?

[SIM/NÃO — se sim, listar sub-operadores]

TRANSFERÊNCIA INTERNACIONAL?

[SIM/NÃO — se sim, fundamento Art. 33]

DUE DILIGENCE APLICADA

[Score% — opcional, baseado em
questionário]

CADASTRADO EM / POR

[DATA — NOME do responsável]

💡 EXEMPLO PREENCHIDO

Operador: Empresa Hipotética Tecnologia LTDA · CNPJ 00.000.000/0001-00

Serviço: hospedagem em nuvem do sistema de Ouvidoria (SaaS) · Papel:
OPERADOR · Contrato: 045/2024 · Vigência: 01/01/2024 a 31/12/2026

Cláusulas LGPD: SIM · Tipo: CONTRATO_NOVO_CLAUSULAS · Nível de risco:
MÉDIO

Dados: cadastrais + conteúdo das manifestações · Volume: ~1.200 titulares/ano

Subcontratação: não · **Transferência internacional:** não (DC em SP)



Registro de Solicitação DSR

Direitos do Titular · 15 dias úteis

QUANDO USAR

Na **Fase 6**, para cada solicitação recebida pelo canal DSR. Mantém registro do prazo de resposta (**15 dias úteis** — Art. 19 II LGPD) e da resposta dada. **Reproduzir 1 ficha por solicitação.**

FORMULÁRIO

NÚMERO DA SOLICITAÇÃO

[PROTOCOLO INTERNO]

DATA DE RECEBIMENTO

[DATA]

CANAL DE ENTRADA

[E-mail / Formulário web / Telefone /
Presencial / Carta]

NOME DO TITULAR

[NOME DO TITULAR]

CONTATO DO TITULAR

[E-MAIL ou TELEFONE]

IDENTIDADE CONFIRMADA?

[SIM/NÃO/COM RESSALVAS — método de
confirmação]

TIPO (ART. 18)

[CONFIRMAÇÃO / ACESSO / CORREÇÃO / ANONIMIZAÇÃO / BLOQUEIO / ELIMINAÇÃO / PORTABILIDADE / OPOSIÇÃO / INFO COMPARTILHAMENTO / REVOGAÇÃO]

DESCRIÇÃO

[Texto literal do pedido OU resumo]

SETOR ENVOLVIDO

[QUAL setor trata os dados solicitados]

STATUS ATUAL

ABERTA

EM ANÁLISE

RESPONDIDA

NEGADA

PRAZO DE RESPOSTA

[15 dias úteis · DATA LIMITE]

DATA DA RESPOSTA

[DATA]

RESPOSTA DADA

[Texto da resposta enviada ao titular]

JUSTIFICATIVA (SE NEGADA)

[Fundamento legal — Art. 18 §4º / outros]

RESPONSÁVEL

[NOME — DPO ou pessoa designada]



Indicadores recomendados



% no prazo

% respondidas em até 15 dias úteis (meta: 100%)



Tempo médio

Em dias úteis, por categoria de solicitação



Distribuição por tipo

Qual direito é mais exercido?



Distribuição por canal

E-mail, formulário, telefone, presencial

💡 EXEMPLO PREENCHIDO

Protocolo: DSR-2027-014 · Recebida em 10/04/2027 · Canal: e-mail
[\[email protected\]](#)

Titular: João Silva ([\[email protected\]](#)) · Identidade confirmada via cópia de RG

Tipo: ACESSO · Solicita cópia das informações em manifestações de Ouvidoria do último ano

Setor: Ouvidoria · **Status:** RESPONDIDA · **Prazo:** 02/05/2027 · **Data resposta:** 18/04/2027 (8 dias úteis)

Resposta: encaminhada cópia das 3 manifestações, com tarja em dados de terceiros

Responsável: Maria Silva (Encarregada)



ENCERRAMENTO

20 templates, *um programa.*

Este Pacote é o complemento prático da **Cartilha do PGP**. Ao preencher cada modelo na ordem das fases — **Preliminar** → **7** — sua Instituição constrói, passo a passo, o seu Programa de Governança em Privacidade.

Lembretes para guardar



Salve uma cópia antes de editar

O original fica intacto para consulta futura ou distribuição.



Preencha gradualmente

Siga a ordem das fases — Preliminar primeiro, demais conforme o Plano de Ação.



Revise anualmente

Modelos preenchidos viram instrumentos vivos do PGP — manutenção é parte do método.

